



Implementation & Methodology of Project Threat Graph

Project Objective:

The goal is Unified Cyber Resilience by combining Intelligent Attack Surface Visualization with Continuous Threat Exposure Management. It focuses on the continuous discovery and risk reduction of all internet-facing assets.

Summary of the project:

This project constitutes a robust framework aimed at accomplishing Unified Cyber Resilience by combining Intelligent Attack Surface Visualization and Continuous Threat Exposure Management capabilities. Firstly, Attack Surface Management (ASM) constitutes one of the main aspects of the project. ASM implies continuous discovery, cataloguing, and risk reduction of all internet-connected digital assets that include Shadow IT.

The project employs a multi-layer technical architecture starting from Discovery Sources (L0), which includes Shodan and Nuclei up to complex solutions using distributed execution with Kubernetes, event streaming with Kafka, and advanced analytics with Elasticsearch. A broad taxonomy of discovery types is used, which consists of different approaches such as passive reconnaissance (Certificate Transparency logs) and active scanning.

ThreatGraph project uses the Risk Scoring Framework, which considers various risks based on business priorities such as Asset Criticality and Blast Radius, as well as threat scoring frameworks like CVSS 4.0 and EPSS. In order to accomplish efficiency, ThreatGraph defines strict Service Level Objectives, which include high-level Asset Coverage Ratio (above 95%), fast Discovery Lag (< 24 hrs) and MTTR (< 7 days).

Tech Stack:

1. Scanning & Discovery (L0- L1):

The tools below will be responsible for active and passive reconnaissance to find assets:

- **Passive discovery:** crt.sh (Certified Transparency Logs), Shodan, Censys, ChaosDB.
- **Active Scanning:** Masscan and ZMap for IPv4 exhaustive scanning; Nmap for detailed port identification and service identification.



- **Vulnerability Detection:** Nuclei using its library of CVE templates.

2. Backend & Messaging (L3- L4):

This layer raw scans data into meaningful asset fingerprints:

- **Languages:** Go for high performance grpc services and FastAPI for the core API logic.
- **Messaging:** Kafka or NATS to handle real time event streaming streaming between scanners and the database.
- **Orchestration:** Temporal.io to manage the lifecycle of scan jobs and automated workflows.

3. Data Storage & Analytics:

To maintain time-based and historical record of attack surface we need to specialize database:

- **Time-Series Database:** Timescale DB to track asset changes overtime.
- **Cache:** Redis for fast lookups of active asset states.
- **Search Engine:** Elastic Search for visualizing the attack surface and performing rapid queries.
- **Advanced Vector Search:** Pinecone for building the intelligent Graph aspect of the project.

4. Visualization and Security:

- **Gateway:** Kong combined with ModSecurity (WAF) to protect the API.
- **Visualization:** Kibana to track metrics like discovery lag < 24 and MTTR < 7d.

Roadmap in phases:

Phase 1: Discovery & Execution Plane:

The focus here is setting up the eyes of the system to eliminate Shadow IT

- **Passive Recon Setup:** Integrate APIs for crt.sh, Shodan, and Censys to find subdomains and publicly known assets without direct interaction.
- **Active Scanning Engine:** Deploy Masscan and Nmap to perform exhaustive IPv4 scans and service identification.
- **Cloud Ingestion:** Configure connectors for AWS, Azure, and GCP APIs to pull metadata for cloud-native assets.



Phase 2: Data Normalization & Messaging:

In this phase, build the brain that organizes raw data into a usable inventory

- **Event Streaming:** Implement Kafka or NATS to stream scan results as events, ensuring the system can handle high Scan Velocity.
- **Asset Fingerprinting:** Develop microservices (using Go or FastAPI) to normalize raw data into Asset Fingerprints (IP:Port:Service:Version).
- **Storage:** Set up TimescaleDB for long-term asset history and Redis for real-time state tracking.

Phase 3: Intelligence & Risk Prioritization:

This phase moves the project from simple mapping to Intelligent Attack Surface Visualization.

- **Vulnerability Correlation:** Use Nuclei templates to check discovered assets for specific CVE signatures.
- **Quantitative Scoring:** Apply CVSS 4.0 and EPSS models to rank findings based on severity and exploit probability.
- **Contextual Analysis:** Tag assets by Criticality (Tier 0-3) and calculate the Blast Radius to prioritize remediation.

Phase 4: Orchestration & Analytics:

The final phase focuses on making the defense proactive, adaptive, and robust.

- **Workflow Automation:** Deploy Temporal.io to schedule recurring scans and automate alerting workflows.
- **Visualization:** Connect Elasticsearch and Kibana to create dashboards that track your SLOs, such as keeping Discovery Lag under 24 hours.
- **Compliance Mapping:** Ensure your findings are automatically mapped to frameworks like NIST 800-53 or SOC2 for reporting.

The expected outcome:

Expected Key Metrics:

- **Asset Coverage Ratio:** Over 95% of all digital assets identified.
- **Discovery Latency:** Less than 24 hours between exposure and discovery.
- **MTTP (Mean Time To Prioritize):** Below 1 hour to prioritize risks.



- **MTTR (Mean Time To Remediate):** Critical risks addressed within 7 days.

Outcomes:

- **Total Visibility:** Elimination of **Shadow IT** (unauthorized assets) through passive, active, and cloud-native scanning.
- **Smart Prioritization:** Using **CVSS 4.0** and **EPSS** to rank vulnerabilities by their likelihood of being exploited.
- **Proactive Defense:** Moving from reactive fixing to a real-time, automated risk identification and mitigation cycle.

Conclusion of Results:

- **Live Attack Surface Map:** A complete inventory of IPs, domains, and cloud resources.
- **Attack Path Visualization:** Mapping multi-hop exploitation chains from low-security assets to critical targets.
- **Compliance Alignment:** Mapping all security controls to frameworks like **NIST 800-53** and **SOC2**.